

CourtManager Pro

Informe ejecutivo para Atlético de Madrid

3 de agosto de 2026 · Auditoría comercial + readiness de seguridad · Documento de evaluación

Veredicto: sí merece la pena un piloto de utilería del primer equipo. El producto ya incorpora pack ATM, sincronización con fuentes oficiales del club y controles de acceso en tres capas. Existe una cuenta demo limitada (sin superadmin) para que Atleti Lab pruebe sin depender del propietario del sistema.

1. ¿Qué es y qué problema resuelve?

CourtManager Pro es el sistema operativo de utilería de un club profesional: plantilla, tallas, inventario, solicitudes, viajes, lavandería, material médico, alertas y checklists de partido — en una sola aplicación web.

Sustituye Excel + WhatsApp + conocimiento individual por un punto de verdad con trazabilidad, roles y alertas automáticas.

2. Beneficios tangibles para ATM

Beneficio	Impacto operativo
Ahorro de tiempo	Menos búsquedas y re-trabajo entre turnos
Control de stock / €	Almacén valorado, mínimos y caducidades
Menos errores	QR, tallas por jugador, aprobaciones
Preparación de partido	Checklists, convocatoria, transporte, packing
Seguridad y RGPD	Roles, RLS, auditoría, registro cerrado
Datos oficiales ATM	Sync plantilla y calendario atleticodemadrid.com

3. Acceso demo para evaluación (sin superadmin)

Email: demo.atm@courtmanager.pro

Contraseña: 123456

Ámbito: solo Atlético de Madrid · rol utilería · sin cambios de plataforma

La contraseña es deliberadamente corta para facilitar la demo. Está mitigada con: kill-switch (ATM_DEMO_ENABLED), aislamiento al team ATM, rate limit reforzado (3 intentos), sin privilegios de superadmin y banner de evaluación visible.

Tras la evaluación: desactivar con `ATM_DEMO_ENABLED=false` / `NEXT_PUBLIC_ATM_DEMO_ENABLED=false` y rotar o eliminar la cuenta.

4. Seguridad — lo que un pentest verá

Seguridad es prioritaria. El sistema aplica **tres capas reales** en producción:

- 1. **Middleware:** sin sesión → login / 401; registro cerrado; crons con secreto.
- 2. **APIs:** usuario obligatorio + pertenencia a equipo (anti-IDOR).
- 3. **Base de datos:** Row Level Security por equipo en PostgreSQL (Supabase).

Control	Estado
Passkeys / WebAuthn (cuentas clave)	Disponible
Tokens fuera del JSON (cookies de sesión)	Endurecido
Rate limit login (IP + email)	Activo
HSTS, CSP, anti-clickjacking, COOP/CORP	Activo
Políticas legales RGPD / LSSI	Publicadas en la app
Cuenta demo ATM aislada	Activa con kill-switch
Bloqueo clic derecho / F12	Cosmético — no es control real

Qué NO se vende como hecho

- Certificación ISO/SOC2 (no incluida en el repositorio).
- SSO corporativo Azure AD / Okta (fase 2 si TI lo exige).
- Integración nativa ERP/CRM (posible vía APIs; no conector listo).

5. Alcance del piloto recomendado (4–8 semanas)

- Inventario + tallas + solicitudes + alertas.
- Almacén / movimientos y checklist pre-partido.
- 3–5 KPI: tiempo de preparación, roturas de stock, % solicitudes a tiempo.
- Usuarios: utillería + 1 perfil médico + 1 consulta (además del demo ATM).

6. Fortalezas (ordenadas)

- 1. Dominio real de utilería de élite (ciclo completo).
- 2. Seguridad en capas + roles + trazabilidad.
- 3. Pack y sync específicos de ATM.
- 4. Arquitectura evolucionable (APIs, multi-equipo).
- 5. UX orientada al utillero (baja curva de formación).

7. Riesgos residuales y mitigación

Riesgo	Mitigación
Algunos checklists en navegador	Migrar a BD en fase piloto
Contraseña demo corta (123456)	Kill-switch + aislamiento + desactivar tras demo
Rate limit en memoria (serverless)	Redis/Upstash en fase 2
Sin SSO aún	Acordar con TI si es requisito de go-live

8. Conclusión para dirección

CourtManager Pro es una buena inversión de piloto: digitaliza la utilería del primer equipo con producto ya adaptado a ATM, reduce riesgos operativos y de control, y permite evaluar con una cuenta limitada sin abrir el acceso de superadmin. La seguridad está diseñada para resistir pruebas de acceso indebido; los puntos abiertos son conocidos y planificables.

Próximo paso propuesto

- 1. Activar demo ATM en el entorno de evaluación.
- 2. Sesión de 60–90 min con utillería / Atleti Lab.
- 3. Decisión de piloto formal con KPI y calendario.